

Clase 5

1. Introducción a la Ciberseguridad

1.1. X.509: La infraestructura invisible de la confianza digital

El estándar **ITU-T X.509**, establecido en **1988** como parte de la familia **X.500**, constituye la base de la **Infraestructura de Clave Pública (PKI)**, pilar esencial de la confianza digital moderna.

La versión **X.509 v3 (1997)** introdujo extensiones que permiten personalizar los certificados, haciéndolos aplicables en múltiples contextos: **HTTPS, VPN, S/MIME, Code Signing e IoT**.

Su objetivo principal es asegurar la **vigencia técnica y arquitectónica** de los sistemas de autenticación y cifrado a lo largo del tiempo.

1.2. Arquitectura y fundamentos técnicos

El modelo de PKI basado en X.509 adopta una **estructura jerárquica** compuesta por una **CA raíz, Sub-CAs, Autoridades de Registro (RA)** y **usuarios finales**.

Los certificados X.509 vinculan una **identidad verificable** con una **clave pública**, empleando codificaciones **ASN.1 DER/BER**.

Las **extensiones X.509v3** otorgan compatibilidad y personalización, permitiendo definir atributos como políticas de certificación, usos de clave o restricciones de nombre.

1.3. Diseño modular y longevidad

La longevidad del modelo X.509 radica en su **diseño modular, extensible y estandarizado**.

Desde su creación en 1988, ha evolucionado sin rupturas hasta **TLS 1.3 (2018)**, manteniendo compatibilidad y relevancia global.

Su documentación formal y el proceso de estandarización continua garantizan interoperabilidad entre sistemas y organizaciones.

2. Aplicaciones y Extensiones del Modelo X.509

2.1. RPKI (Resource Public Key Infrastructure)

El protocolo **BGP (Border Gateway Protocol)** carece de autenticación nativa, lo que lo hace susceptible a ataques de **route hijacking** o **prefix hijacking**.

La **RPKI** asocia criptográficamente **bloques de direcciones IP (IPv4/IPv6)** y **números de sistema autónomo (ASN)** con **certificados X.509** emitidos por los **RIR** (LACNIC, ARIN, RIPE, etc.).

Cada certificado genera un **ROA (Route Origin Authorization)** que define qué **AS** está autorizado a anunciar un prefijo IP, permitiendo a los routers validar criptográficamente los anuncios y mitigar ataques.

2.2. SG11 (ITU-T): Señalización y autenticación en telecomunicaciones

El grupo **SG11 del ITU-T** desarrolla normas de interoperabilidad y autenticación entre operadores y dispositivos de red.

X.509 se emplea como **mecanismo de autenticación mutua** entre nodos, garantizando **integridad y autenticidad** en las sesiones de señalización (por ejemplo, **SIP, H.323, 5G Core**).

De este modo, los equipos de telecomunicaciones intercambian certificados X.509 para confirmar su identidad antes de establecer comunicaciones seguras.

2.3. TLS/SSL: Validación en tiempo real

Los protocolos **TLS/SSL**, esenciales para **HTTPS**, utilizan certificados **X.509** emitidos por una **CA** para autenticar servidores y cifrar la comunicación.

El cliente (navegador) valida la **firma digital** y la **cadena de confianza**, comprobando que el certificado no esté comprometido mediante:

- **CRL (Certificate Revocation List)**, listas de revocación publicadas por la CA.
- **OCSP (Online Certificate Status Protocol)**, validación en línea del estado del certificado.
- **CT Logs (Certificate Transparency Logs)**, registros públicos inmutables que previenen el uso de certificados fraudulentos.

3. Nuevos Contextos Tecnológicos

3.1. DPKI (Decentralized Public Key Infrastructure)

La **DPKI** representa la evolución del modelo PKI tradicional, sustituyendo la jerarquía de CAs por una **confianza distribuida** basada en **blockchain** o **ledger distribuido (DLT)**.

Cada entidad (persona, organización o dispositivo) genera y publica su propia clave pública en un registro descentralizado.

En lugar de una CA central, la **verificación se basa en consenso** o en **anclajes de confianza distribuidos**, integrando conceptos como **Identidad Autosoberana (SSI)** y **Verifiable Credentials (W3C)**.

Por ejemplo, un dispositivo IoT podría registrar su identidad en blockchain, permitiendo que otros nodos verifiquen su autenticidad sin depender de una CA.

3.2. Post-Quantum Cryptography (PQC)

La **criptografía post-cuántica** busca resistir ataques de futuras computadoras cuánticas.

Durante la **transición híbrida**, se emplearán simultáneamente **claves clásicas (RSA/ECC)** y **claves post-cuánticas** (como **CRYSTALS-Kyber** o **Dilithium**).

Los certificados **X.509** se adaptarán para incluir ambos tipos de claves y firmas, garantizando **compatibilidad retroactiva** con **TLS, VPNs y PKI existentes** sin comprometer la seguridad.

3.3. Agentic AI: Identidad verificable entre agentes autónomos

Los **agentes autónomos** (IA que actúan o deciden por sí mismos) requerirán **identidades digitales verificables** para interactuar de forma segura.

El modelo **PKI/X.509**, o sus extensiones futuras, permitirá que cada agente posea un **certificado digital o token criptográfico** que respalde su identidad, reputación y permisos.

Esto asegura que las comunicaciones entre agentes estén **firmadas y autenticadas**, posibilitando transacciones verificables entre IA y humanos dentro de marcos de confianza como **DPKI o PKI federadas**.

3.4. EU Cyber Resilience Act (CRA): Dependencia reforzada en PKI

El **Cyber Resilience Act (CRA)**, regulación de la **Unión Europea (2024)**, obliga a fabricantes y desarrolladores de software a garantizar **autenticidad, integridad y actualizaciones seguras**.

Refuerza la dependencia de la **infraestructura PKI** mediante el uso obligatorio de **firmas digitales X.509** para:

- Firmar firmware y software.
- Autenticar dispositivos conectados.
- Validar actualizaciones y comunicaciones.

De este modo, X.509 y PKI se consolidan como pilares de la confianza en el ecosistema digital europeo.

4. Riesgos y Desafíos Operativos

4.1. Escalabilidad y validación

Los mecanismos de validación (OCSP, CRL, SCTs) pueden generar problemas de **latencia, carga y disponibilidad**, afectando la eficiencia de grandes infraestructuras.

4.2. Sostenibilidad de CAs y RAs

La **concentración de autoridades** y la **dependencia de pocos actores** conlleva riesgos sistémicos, comprometiendo la resiliencia global del ecosistema PKI.

4.3. Brecha de especialistas y migración post-cuántica

Existe una falta creciente de expertos en **PKI, ASN.1 y criptografía avanzada**, lo que dificulta la adaptación hacia un entorno **post-cuántico** compatible y seguro.

5. Lecciones de Ingeniería

5.1. Principios de diseño duradero

Los sistemas tecnológicos duraderos comparten tres principios fundamentales:

- **Modularidad y abstracción adecuada.**
- **Estandarización formal y documentación abierta.**

- **Evolución incremental sin ruptura.**

5.2. X.509 como arquitectura resiliente

El caso de X.509 demuestra que la **resiliencia técnica** y la **vigencia temporal** son consecuencia directa del **buen diseño estructural** y la **interoperabilidad global**.

6. Conclusiones y Referencias

6.1. El buen diseño como base de la vigencia tecnológica

"El secreto de la vigencia tecnológica está en el buen diseño."

X.509 continúa siendo el **sostén de la confianza digital en Internet**, integrándose en tecnologías emergentes sin perder compatibilidad.

6.2. Referencias normativas y técnicas

- ITU-T X.509 (11/2019)
 - RFC 5280
 - NIST SP 800-208
 - EU CRA (2024)
 - Erik Andersen – ITU-T Q1 DPKI Design Talk
-

7. Frameworks y Regulaciones en Ciberseguridad

7.1. GDPR (General Data Protection Regulation – UE)

7.1.1. Principios del GDPR

Aplica a todas las organizaciones que procesen datos de residentes en la **Unión Europea**.

Sus principios son: **licitud, transparencia, finalidad, minimización, exactitud, limitación del almacenamiento, integridad y responsabilidad**.

7.1.2. Seguridad de la información como pilar del GDPR

El GDPR exige **medidas técnicas y organizativas** para proteger los datos, uniendo la **protección legal** con la **ciberseguridad práctica**.

Entre ellas:

- **Cifrado y seudonimización.**
- **Control de acceso y autenticación.**
- **Gestión de vulnerabilidades y resiliencia.**
- **Notificación de incidentes en 72 h.**

Se complementa con **ISO 27001, NIST CSF y COBIT 2019.**

7.1.3. Derechos y responsabilidades

El responsable del tratamiento debe demostrar **accountability**.

Los usuarios gozan de derechos como **acceso, rectificación, supresión (derecho al olvido), portabilidad, limitación y oposición.**

Se requiere aplicar **Privacy by Design** y **Privacy by Default**. Las sanciones pueden alcanzar hasta el **4 % del volumen global de negocios anual.**

7.1.4. Privacy by Design & by Default

La protección de datos debe incorporarse desde el diseño de los sistemas.

Sus principios incluyen:

- Proactividad, prevención y transparencia.
- Privacidad por defecto.
- Seguridad de extremo a extremo.
- Respeto por el individuo.

7.1.5. Estrategias técnicas complementarias

- **Minimizar:** recolectar solo datos necesarios.
- **Ocultar:** cifrar o enmascarar información sensible.
- **Separar:** distribuir datos para evitar correlaciones.
- **Agregar:** anonimizar información.
- **Informar y controlar:** transparencia y autonomía del usuario.
- **Cumplir y demostrar:** políticas auditables.

7.1.6. Tipos de datos personales

- **Identificativos directos:** nombre, DNI, imagen.
- **Indirectos:** IP, geolocalización, hábitos.
- **Sensibles:** salud, religión, ideología, orientación sexual.
- **Financieros y de menores:** requieren controles adicionales.

7.1.7. Implicancias técnicas

Los **datos sensibles** exigen **cifrado fuerte**, **segmentación de acceso** y **monitoreo activo**, conforme al nivel de riesgo.

7.1.8. Ciberseguridad y técnicas de cifrado en el GDPR

- **En tránsito:** TLS 1.3, HTTPS, VPN, SSH.
- **En reposo:** AES-256, ChaCha20, BitLocker, LUKS.
- **Cifrado homomórfico o seudonimización** para análisis.

Además, **MFA**, **least privilege**, **resiliencia** (backups cifrados) y **notificación de incidentes** son medidas clave.

7.2. ISO/IEC 27032 (Cybersecurity Guidelines)

7.2.1. Propósito y alcance

Norma internacional que proporciona **directrices específicas para la ciberseguridad**, diferenciándola de la **seguridad de la información** tratada por ISO/IEC 27001.

7.2.2. Relación con ISO/IEC 27001

Mientras ISO 27001 gestiona la información como activo organizativo, ISO 27032 amplía la protección a **infraestructuras críticas**, **usuarios finales** y **ecosistemas digitales interconectados**.

7.2.3. Aplicación práctica y marco de referencia

Su adopción promueve la colaboración entre sectores público y privado, la educación en seguridad y la **protección integral frente a ciberamenazas globales**